

ITGC (Information Technology General Controls) are controls that support the reliable operation of IT systems, ensuring they function as intended and deliver accurate information. These controls are critical in managing risk and ensuring compliance with standards such as ISO 27001. Below are the primary ITGC categories, their use cases, and how they map to ISO 27001 controls:

1. Access Control (Logical Security)

- **Use Case:** Ensuring only authorized personnel can access sensitive data or systems. For instance, in a financial institution, employees can access customer data only through multi-factor authentication.
- **ISO 27001 Mapping:**
 - **A.9.1.1** - Access control policy.
 - **A.9.2.1** - User registration and de-registration.
 - **A.9.4.1** - Information access restriction.

2. Change Management

- **Use Case:** Managing changes to critical applications, databases, or systems. For example, updating financial software requires approval and testing before it goes live.
- **ISO 27001 Mapping:**
 - **A.12.1.2** - Change management.
 - **A.12.5.1** - Installation of software on operational systems.

3. Backup and Recovery

- **Use Case:** Ensuring data can be recovered after a disaster or system failure. For instance, regular backups are made and tested for a business-critical ERP system.
- **ISO 27001 Mapping:**
 - **A.12.3.1** - Backup.

4. Incident Management

- **Use Case:** Handling security incidents like breaches or system outages. A process must be in place to detect, report, and recover from incidents. For example, a DDoS attack is identified and mitigated using predefined response procedures.
- **ISO 27001 Mapping:**
 - **A.16.1.1** - Responsibilities and procedures.
 - **A.16.1.4** - Assessment of and decision on information security events.

5. Physical Security

- **Use Case:** Controlling physical access to data centers and critical IT assets. An example is using biometric scans to access server rooms in a corporate office.
- **ISO 27001 Mapping:**

- **A.11.1.1** - Physical security perimeter.
- **A.11.2.1** - Equipment siting and protection.

6. System Development and Acquisition

- **Use Case:** Ensuring secure development practices are followed. For example, a new CRM application is tested for security vulnerabilities before deployment.
- **ISO 27001 Mapping:**
 - **A.14.2.1** - Secure development policy.
 - **A.14.1.1** - Information security requirements analysis and specification.

7. Data Integrity Controls

- **Use Case:** Ensuring data integrity during data processing, such as using validation checks to prevent invalid data from being entered into a system.
- **ISO 27001 Mapping:**
 - **A.14.1.2** - Secure application design.
 - **A.12.4.1** - Logging and monitoring.

8. Vendor and Third-Party Management

- **Use Case:** Managing risks related to third-party vendors that access company systems or data. For instance, cloud service providers must comply with security standards.
- **ISO 27001 Mapping:**
 - **A.15.1.1** - Information security policy for supplier relationships.
 - **A.15.2.1** - Monitoring and review of supplier services.

9. System Operation Controls

- **Use Case:** Ensuring systems are monitored for performance and security. For example, a bank monitors its systems for unusual activity to prevent fraud.
- **ISO 27001 Mapping:**
 - **A.12.1.3** - Capacity management.
 - **A.12.4.1** - Event logging.

10. Segregation of Duties

- **Use Case:** Ensuring that no individual has excessive system access or control that could lead to fraud or error. For instance, one person approves a transaction, and another processes it.
- **ISO 27001 Mapping:**
 - **A.6.1.2** - Segregation of duties.

11. Monitoring and Logging

- **Use Case:** Tracking system activity to detect anomalies or unauthorized access. For example, logging all login attempts on critical systems.
- **ISO 27001 Mapping:**
 - **A.12.4.1** - Logging and monitoring.
 - **A.12.4.3** - Administrator and operator logs.

12. Patch Management

- **Use Case:** Applying security patches to systems and applications in a timely manner. For instance, deploying critical OS patches within 48 hours.
- **ISO 27001 Mapping:**
 - **A.12.6.1** - Management of technical vulnerabilities.

Summary Table

ITGC Control	ISO 27001 Control
Access Control	A.9.1.1, A.9.2.1, A.9.4.1
Change Management	A.12.1.2, A.12.5.1
Backup and Recovery	A.12.3.1
Incident Management	A.16.1.1, A.16.1.4
Physical Security	A.11.1.1, A.11.2.1
System Development	A.14.2.1, A.14.1.1
Data Integrity	A.14.1.2, A.12.4.1
Vendor Management	A.15.1.1, A.15.2.1
System Operation	A.12.1.3, A.12.4.1
Segregation of Duties	A.6.1.2
Monitoring and Logging	A.12.4.1, A.12.4.3
Patch Management	A.12.6.1

This mapping ensures that ITGCs are properly aligned with ISO 27001 requirements, enabling organizations to maintain security and compliance across their IT environments.